AWS Config

概要

- 11. セキュリティ設計　に記載の通り、 全てのAWSアカウント、全てのリージョンに対してAWS Configを設定する。

レコーダー

項目	初期値	検証(東京)	検証(他リージョン)	本番(東京)	DR本番(大阪)	本番(他リージョン)	備考
レコーダー	無効	有効	有効	有効	有効	有効	

記録方法

項目	初期値	検証(東京)	検証(他リージョン)	本番(東京)	DR本番(大阪)	本番(他リージョン)	備考
記録方法(記録戦略)	カスタマイズ可能なオーバーライドのあるすべてのリソースタイプを記録	カスタマイズ可能なオーバーライドのあるすべてのリソースタイプを記録	カスタマイズ可能なオーバーライドのあるすべてのリソースタイプを記録	カスタマイズ可能なオーバーライドのあるすべてのリソースタイプを記録	カスタマイズ可能なオーバーライドのあるすべてのリソースタイプを記録	カスタマイズ可能なオーバーライドのあるすべてのリソースタイプを記録	
記録方法(デフォルトの記録頻度)	連続	連続	連続	連続	連続	連続	変更が発生するたびに、設定変更を継続的に記録する
オーバーライド設定のあるリソースタイプ	・AWS IAM Policy ・AWS IAM User ・AWS IAM Role ・AWS IAM Group	なし	・AWS IAM Policy ・AWS IAM User ・AWS IAM Role ・AWS IAM Group	なし	・AWS IAM Policy ・AWS IAM User ・AWS IAM Role ・AWS IAM Group	・AWS IAM Policy ・AWS IAM User ・AWS IAM Role ・AWS IAM Group	・東京リージョンについては、全てのリソースに対して、変更が発生するたびに継続的に記録するため、オーバーライドは設定しない ・グローバルリソースについて、東京側で記録するため東京以外のリー

							ジョンではConfig記録から除外する

- ※補足：オーバーライドについて
  - オーバーライドを設定する場合、特定のリソースについて、下記から選択する。
    - Config記録から除外する
    - 設定変更を継続的に記録ではなく1日1回の日次記録に変更する

データガバナンス

項目	初期値	検証(東京)	検証(他リージョン)	本番(東京)	DR本番(大阪)	本番(他リージョン)	備考
データガバナンス(データ保持期間)	7年	7年	7年	7年	7年	7年	最短30日から最長7年(2557日)の間で選択するデフォルト設定は7年
データガバナンス(IAMロール)	既存のAWS Configサービスリンクロールを使用(AWSServiceRoleForConfig)	managed-test-iam-role-config	managed-test-iam-role-config	managed-prod-iam-role-config	managed-prod-iam-role-config	managed-prod-iam-role-config	

配信方法

項目	初期値	検証(東京)	検証(他リージョン)	本番(東京)	DR本番(大阪)	本番(他リージョン)	備考
配信方法(S3バケット名)	バケットの作成	managed-test-s3-bucket-config	managed-test-s3-bucket-config	managed-prod-s3-bucket-config	managed-dr-prod-s3-bucket-config	managed-prod-s3-bucket-config	Config用に作成したバケットを指定する
プレフィックス	-	-	-	-	-	-	
Amazon SNSトピ	-	-	-	-	-	-	変更が記録されるたびに通

ック							知されるため、本設定は無効とする。

ルール

- Configルールは東京リージョンのみに設定し、AWSがベストプラクティスに基づいて提供する「AWS マネージド型ルール」を使用する。

利用ルール	説明
mfa-enabled-for-iam-console-access	マネジメントコンソールを使用するすべてのIAMユーザーに対して、多要素認証 (MFA) が有効になっているかどうかを確認する
vpc-default-security-group-closed	defaultのセキュリティグループがインバウンドまたはアウトバウンドのトラフィックを許可していないかどうかを確認する
vpc-sg-port-restriction-check	フルオープン(0.0.0.0/0)のセキュリティグループがあるか確認する
cloudtrail-enabled	AWS アカウントで AWS CloudTrail 証跡が有効になっているかどうかを確認する
cloud-trail-log-file-validation-enabled	CloudTrailでログファイルの整合性検証が有効になっているかを確認する
multi-region-cloudtrail-enabled	マルチリージョンの証跡取得ができているかを確認する
s3-bucket-public-read-prohibited	S3 バケットでパブリック読み取りアクセスが許可されていないかどうかを確認する
s3-bucket-public-write-prohibited	S3 バケットでパブリック書き込みアクセスが許可されていないかどうかを確認する
guardduty-enabled-centralized	AWS リージョンで Amazon GuardDuty が有効になっているかどうかを確認する

- ※参考
  - AWS Config マネージドルールのリスト
    - https://docs.aws.amazon.com/ja_jp/config/latest/developerguide/managed-rules-by-aws-config.html